UNIVERSITI TEKNOLOGI MARA
MARKING SCHEME

COURSE	:	COMPUTER SECURITY
COURSE CODE	:	CSC662
EXAMINATION	:	OCTOBER 2026 (MOCK)
TIME	:	3 HOURS

MARKING SCHEME NOTES

1. This marking scheme accompanies the CSC662 mock paper (October 2026). Computed answers show working; theory answers are supported by lecture slides (not lecturer-marked) with a verbatim quote and slide citation.

2. Supported theory marking points quote the lecture decks; any unresolved slot would remain a visible placeholder.

3. Part A = 10 x (2 + 6); Part B = 2 x (5 + 5); total = 100 marks.

4. Computed: 1 slot(s). Supported theory: 23 slots. Placeholders: 0.
Questions and answers are for local study use only.

5. Near-copy rejection used all 35 past papers; style widening is recorded per slot.

FOR MARKERS' USE ONLY

This marking scheme consists of 15 printed pages

© Hak Cipta Universiti Teknologi MARA

CSC662 - MARKING SCHEME (MOCK OCTOBER 2026)

Labels: computed / supported by lecture slides (not lecturer-marked) / placeholder. No official marking scheme exists for the real CSC662 papers; this is generated for the mock.

Entailment labels: supported = the quote directly supports the marking point (or the point passed the stem-overlap gate without an LLM check); partly supported = the quote supports part of the point or is ambiguous; not supported = the quote does not support the point. Only 'not supported' points triggered regeneration.

Part A: 10 x (2 + 6) = 80 marks. Part B: 2 x (5 + 5) = 20 marks. Total: 100 marks. Slots: 1 computed, 23 supported by lecture slides, 0 placeholder.

Methods: computed answers use verified solvers. Theory answers are supported by lecture slides (not lecturer-marked). Each marking point carries a verbatim quote, a deck/slide/chunk citation and a term-overlap score; low overlap is flagged for human review. Sources are restricted to the slot topic's allowed decks, and a slide is not reused across questions where an alternative exists.

PART A - QUESTION 1

A1a - 2 marks - computed - matches lecture slides 5-9 (Caesar shift 3 examples)

Question:

Using Caesar Cipher technique, decrypt the following ciphertext with a shift of 7 (replace each letter with the one 7 positions to the left).
KLCPJLYLABYULKHUKDPWLKVUL

Answer: DEVICERETURNEDANDWIPEDONE

Working:

```
K (10) -7 mod 26 -> D
L (11) -7 mod 26 -> E
C ( 2) -7 mod 26 -> V
P (15) -7 mod 26 -> I
J ( 9) -7 mod 26 -> C
L (11) -7 mod 26 -> E
Y (24) -7 mod 26 -> R
L (11) -7 mod 26 -> E
A ( 0) -7 mod 26 -> T
B ( 1) -7 mod 26 -> U
Y (24) -7 mod 26 -> R
U (20) -7 mod 26 -> N
L (11) -7 mod 26 -> E
K (10) -7 mod 26 -> D
H ( 7) -7 mod 26 -> A
U (20) -7 mod 26 -> N
K (10) -7 mod 26 -> D
D ( 3) -7 mod 26 -> W
P (15) -7 mod 26 -> I
W (22) -7 mod 26 -> P
L (11) -7 mod 26 -> E
K (10) -7 mod 26 -> D
V (21) -7 mod 26 -> O
U (20) -7 mod 26 -> N
L (11) -7 mod 26 -> E
```

Suggested marks: 1 mark for identifying the cipher/shift direction; 1 mark for the complete plaintext.
Confidence: computed - matches lecture slides 5-9 (Caesar shift 3 examples).

A1b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Describe substitution ciphers by explaining what operation they perform on plaintext, what serves as the key, which security principle they relate to, and how larger blocks and varying substitutions are used to overcome their weaknesses. Include six points.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment

1	State that substitution ciphers work by replacing each plaintext letter with a different letter.	"In substitution ciphers, we replace the plain-text letters with other letters"	031 - Classical Cryptography, slide 4	031 - Classical Cryptography::s04::1	0.67	supported (ste gate)
2	Identify the substitution rule itself as the key of the cipher.	"The substitution rule is the key"	031 - Classical Cryptography, slide 4	031 - Classical Cryptography::s04::1	0.50	supported (ste gate)
3	Relate substitution to Shannon's principle of confusion.	"Corresponds to Shannon's principle of confusion"	031 - Classical Cryptography, slide 4	031 - Classical Cryptography::s04::1	0.60	supported (ste gate)
4	Explain that using larger blocks of letters as the basis of substitution leads to block ciphers.	"Use larger blocks (a group of letters) as the basis of substitution."	031 - Classical Cryptography, slide 11	031 - Classical Cryptography::s11::1	0.71	supported (ste gate)
5	Note that applying different substitutions removes frequency features and leads to polyalphabetic substitution ciphers.	"Use different substitutions to get rid of frequency features."	031 - Classical Cryptography, slide 11	031 - Classical Cryptography::s11::1	0.25 LOW	partly supporte
6	State that the Arabs broke monoalphabetic substitution by means of frequency analysis.	"The Arabs broke monoalphabetic substitution using frequency analysis"	031 - Classical Cryptography, slide 10	031 - Classical Cryptography::s10::1	0.86	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 031 - Classical Cryptography, slide 10; 031 - Classical Cryptography, slide 11; 031 - Classical Cryptography, slide 4

PART A - QUESTION 2

A2a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain how a chain of trust is established in the Trusted Computing architecture, including the role played by the TPM and the roots of trust.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The chain of trust is the central concept of the Trusted Computing architecture, in which each stage measures and validates the following stage.	"Each stage measures and validates the next one"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.30 LOW	partly supporte
2	The measurements produced during this process are recorded in Platform Configuration Registers (PCRs) held on the TPM.	"Measurements go into Platform Configuration Registers (PCRs) on the TPM"	073 - Trusted Computing, slide 8	073 - Trusted Computing::s08::1	0.55	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 073 - Trusted Computing, slide 8

A2b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Refer to your answer in (a). Explain six components and characteristics of the NGSCB/Nexus architecture, covering the Nexus kernel, the Nexus Computing Agent, and how these relate to the TPM and the platform's trusted mode.

Marking points:

© Hak Cipta Universiti Teknologi MARA

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Nexus is described as a security kernel that is authenticated on boot.	"Security kernel, authenticated on boot"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.80	supported (ste gate)
2	Nexus authenticates trusted programs.	"Authenticates trusted programs"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.75	supported (ste gate)
3	Nexus provides the application interface to the TPM.	"Application interface to TPM"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.60	supported (ste gate)
4	Nexus does not trust the operating system.	"Does not trust OS"	073 - Trusted Computing, slide 14	073 - Trusted Computing::s14::1	0.50	supported (ste gate)
5	The Nexus Computing Agent is a trusted software component.	"Trusted software component"	073 - Trusted Computing, slide 15	073 - Trusted Computing::s15::1	0.40 LOW	supported
6	The NCA runs in a trusted mode that communicates with Nexus.	"Runs in trusted mode that communicates with Nexus"	073 - Trusted Computing, slide 15	073 - Trusted Computing::s15::1	0.83	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 073 - Trusted Computing, slide 14; 073 - Trusted Computing, slide 15

PART A - QUESTION 3

A3a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List TWO (2) reasons why software is insecure, with particular reference to buffer overflows.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Attackers can modify system resources that are critical for program execution, such as the instruction pointer or function call addresses.	"Software insecurity stems from attacker's ability to modify system resources criticial for program execution, e.g. instruction pointer, function call addresses, interrupt addresses, etc."	051 - Software Security, slide 30	051 - Software Security::s30::1	0.79	supported (ste gate)
2	A key source of software insecurity is the failure to validate user input.	"One of the key sources for software insecurity is failed validation of user input."	051 - Software Security, slide 30	051 - Software Security::s30::1	0.86	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 30

A3b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Describe six (6) aspects of the security mechanisms found in Windows systems, covering the overall mechanism set, access control, subjects and credentials, access rights, directory services, and the risks arising from complexity.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Windows provides complex mechanisms covering user account management, object management and access control.	"Windows systems contain complex security mechanisms for user account and object management as well as access control."	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.82	supported (ste gate)
2	Discretionary access control in Windows allows fine-grained control over diverse entities both in the OS	"DACS enable fine-grained access control of heterogeneous entities in Windows itself as well as applications."	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.50	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	and in applications.					
3	In Windows, subjects are processes and threads, and their security credentials are kept in a token.	"Windows subjects are processes and threads."	041 - Windows Security, slide 11	041 - Windows Security::s11::1	0.50	supported (ste gate)
4	Access rights in Windows are encoded as a 32-bit mask and include standard rights such as DELETE and WRITE_DAC.	"Encoded as a 32-bit mask"	041 - Windows Security, slide 16	041 - Windows Security::s16::1	0.25 LOW	partly supporte
5	Active Directory, introduced in Windows 2000, is an LDAP-like directory service that organizes users, groups, credentials, resources and security policies.	"Active directory introduced in Windows 2000 is an LDAP-like directory service for organization of system resources:"	041 - Windows Security, slide 6	041 - Windows Security::s06::1	0.67	supported (ste gate)
6	The complexity of Windows security is a weakness because misconfiguration and implementation bugs can cause severe security incidents.	"The complexity of Windows security mechanisms is also its enemy: misconfiguration as well as implementation bugs may lead to severe security incidents."	041 - Windows Security, slide 21	041 - Windows Security::s21::1	0.58	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 041 - Windows Security, slide 11; 041 - Windows Security, slide 16; 041 - Windows Security, slide 21; 041 - Windows Security, slide 6

PART A - QUESTION 4

A4a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) formal security models that are listed as key security models, and for each, state the specific security concern it addresses.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The Bell-La Padula (BLP) model is a key security model that deals with access control only.	"Bell-La Padula (BLP) model: access control only"	024 - Formal Security Model, slide 5	024 - Formal Security Model::s05::1	0.78	supported (ste gate)
2	The Chinese Wall model is a key security model that addresses the identification of conflicts of interest.	"Chinese Wall model: identification of conflicts of interest"	024 - Formal Security Model, slide 5	024 - Formal Security Model::s05::1	0.75	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 024 - Formal Security Model, slide 5

A4b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the access control structures used to implement access policies, covering the access control matrix, access control lists and capabilities, and state the requirements such structures must satisfy.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Access control structures are the	"Access control structures are mechanisms for implementing	023 - Access Control and	023 - Access Control and	0.60	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	mechanisms through which access policies are implemented, and the access control matrix, capabilities and access control lists are named as such structures.	access policies:"	Authorization, slide 7	Authorization::s07::1		
2	The access control matrix is a basic control structure whose advantages are clarity of definition and ease of verification.	"ACM is a basic control structure."	023 - Access Control and Authorization, slide 8	023 - Access Control and Authorization::s08::1	0.27 LOW	partly supporte
3	The access control matrix suffers from poor scalability and poor handling of changes.	"poor scalability"	023 - Access Control and Authorization, slide 8	023 - Access Control and Authorization::s08::1	0.25 LOW	partly supporte
4	An access control list is an object-centered description of access rights, illustrated by entries such as a document listing which users may read or write it.	"ACL is an object-centered description of access rights:"	023 - Access Control and Authorization, slide 10	023 - Access Control and Authorization::s10::1	0.36 LOW	partly supporte
5	Access control lists give easy access to an object's access rights and are relatively easy to manage using abstractions, but they give a poor overview of rights per subject and make revocation and sharing difficult.	"poor overview of access rights per subject"	023 - Access Control and Authorization, slide 10	023 - Access Control and Authorization::s10::1	0.33 LOW	partly supporte
6	Access control structures must be able to express control policies, allow verification of correctness, and be scalable and manageable.	"an ability to express control policies"	023 - Access Control and Authorization, slide 7	023 - Access Control and Authorization::s07::1	0.25 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 023 - Access Control and Authorization, slide 10; 023 - Access Control and Authorization, slide 7; 023 - Access Control and Authorization, slide 8

PART A - QUESTION 5

A5a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain two characteristics of Trojan horse malware, including how it disguises itself and what harm it can cause once active.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Trojans disguise themselves by appearing to be useful or benign programs so users install them willingly.	"They usually masquerade as helpful or harmless programs"	051 - Software Security, slide 12	051 - Software Security::s12::1	0.10 LOW	supported
2	Once running, a Trojan can steal private data, delete files, record keystrokes, or create a	"begin to steal private data, delete files, log keystrokes or provide an opening for further malware to get installed"	051 - Software Security, slide 12	051 - Software Security::s12::1	0.50	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

	way for additional malware to be installed.					

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 051 - Software Security, slide 12

A5b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss six ways in which malware attacks and propagates through a computer system, referring to the techniques malware uses to spread, hide, and affect the infected host.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Malware can propagate by self-replication, with programs copying themselves to improve their chances of survival.	"To increase their survival chances, programs can replicate themselves"	051 - Software Security, slide 6	051 - Software Security::s06::1	0.55	supported (ste gate)
2	A virus can spread through boot sector infection of distributed media, as demonstrated by early malware included in the boot sector of software diskettes.	"Included in a boot sector of distributed software diskettes"	051 - Software Security, slide 7	051 - Software Security::s07::1	0.40 LOW	partly supporte
3	A worm can propagate remotely by exploiting a debugging feature that allows remote execution, as the Morris worm did across the Arpanet.	"Used a debugging feature of sendmail (remote execution)"	051 - Software Security, slide 7	051 - Software Security::s07::1	0.25 LOW	partly supporte
4	An executable virus can attach its body to a legitimate program so that the infected file carries the malicious code.	"Append a virus body to a program"	051 - Software Security, slide 10	051 - Software Security::s10::1	0.25 LOW	supported
5	A rootkit hides malicious processes and software so that the infected machine remains under the control of the malware author.	"Rootkits are a type of malware that mask malicious processes and software in the infected systems to ensure privileged remote access."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.50	supported (ste gate)
6	Spyware steals user credentials and records activity such as keystrokes and visited sites, which can lead to identity theft.	"They steal user logins and passwords, document sites visited, log keystrokes and even redirect browsers to unwanted sites."	051 - Software Security, slide 13	051 - Software Security::s13::1	0.36 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 051 - Software Security, slide 10; 051 - Software Security, slide 13; 051 - Software Security, slide 6; 051 - Software Security, slide 7

PART A - QUESTION 6

A6a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) impacts of a security attack on the confidentiality, integrity or availability of a system's

assets.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	An attack may cause disclosure, which is unauthorized access to information and harms confidentiality.	"Disclosure - unauthorized access to information"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1	0.44 LOW	supported
2	An attack may cause disruption, which is interruption or prevention of correct operation and harms availability.	"Disruption - interruption or prevention of correct operation"	011 - Introduction to Computer Security, slide 10	011 - Introduction to Computer Security::s10::1	0.50	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 011 - Introduction to Computer Security, slide 10

A6b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss the Samy worm as an example of a cross-site scripting (XSS) attack, covering how the malicious script was injected, how it spread between users, and the scale of the resulting infection.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The worm injected JavaScript into a user profile by manipulating the document body content.	"Inject Javascript into a user profile using document.body.innerHTML"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.60	supported (ste gate)
2	It retrieved the victim's list of friends (heros) by issuing a GET request to a user profile.	"Get the list of user's heros by using a GET on a user profile"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.33 LOW	supported
3	It added Samy as a friend by performing an XML-HTTP request on the addFriends page.	"Add Samy as a field by performing XML-HTTP on the addFriends page"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.78	supported (ste gate)
4	Any user visiting an infected profile had their own profile and friends list infected, enabling self-propagation.	"Any user who visits an infected user's page will gets profile infected with Javascript and his friends list infected with Samy"	052 - Web Security, slide 15	052 - Web Security::s15::1	0.46 LOW	supported
5	The infection ultimately reached approximately one million MySpace profiles.	"Eventually about 1,000,000 MySpace profiles were infected."	052 - Web Security, slide 15	052 - Web Security::s15::1	0.29 LOW	supported
6	The attack exploited the fact that any web application returning unfiltered user input is a potential XSS vulnerability.	"Any web application that returns user input without filtering is a potential XSS vulnerability!"	052 - Web Security, slide 13	052 - Web Security::s13::1	0.69	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 052 - Web Security, slide 13; 052 - Web Security, slide 15

PART A - QUESTION 7

A7a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

State TWO (2) differences between morals and laws as described in the lecture on ethics and computer security.

© Hak Cipta Universiti Teknologi MARA

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Morals are described as traditions of belief concerning right and wrong conduct within a society.	"Morals are traditions of belief about right and wrong conduct"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	0.67	supported (ste gate)
2	Laws are described as formal rules of conduct imposed by a sovereign authority such as a government on its subjects or citizens.	"Laws are formal rules of conduct that a sovereign authority, such as a government, imposes on its subjects or citizens"	071 - Ethics and Computer Security, slide 5	071 - Ethics and Computer Security::s05::1	1.00	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 071 - Ethics and Computer Security, slide 5

A7b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

The ACM Code of Ethics and Professional Conduct guides computing professionals. State SIX (6) obligations that the ACM code places on a computing professional in their conduct and ethical practice.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The professional must aim for high quality in the processes and products of their professional work.	"Strive to achieve high quality in both the processes and products of professional work."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.75	supported (ste gate)
2	The professional must uphold strong levels of competence, conduct and ethical practice.	"Maintain high standards of professional competence, conduct, and ethical practice."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.56	supported (ste gate)
3	The professional must be aware of and respect the rules that apply to their professional work.	"Know and respect existing rules pertaining to professional work."	071 - Ethics and Computer Security, slide 12	071 - Ethics and Computer Security::s12::1	0.57	supported (ste gate)
4	The professional must contribute to the well-being of society and recognise that everyone is a stakeholder in computing.	"Contribute to society and to human well-being, acknowledging that all people are stakeholders in computing."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.56	supported (ste gate)
5	The professional must be honest and trustworthy in their dealings.	"Be honest and trustworthy."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.40 LOW	supported
6	The professional must treat people fairly and avoid discriminatory actions.	"Be fair and take action not to discriminate."	071 - Ethics and Computer Security, slide 11	071 - Ethics and Computer Security::s11::1	0.25 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 071 - Ethics and Computer Security, slide 11; 071 - Ethics and Computer Security, slide 12

PART A - QUESTION 8

A8a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain two ways in which an intrusion detection system contributes to detecting and defending against attacks on a computer system.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	An IDS detects malicious activity occurring in computer systems.	"Detects malicious activity in computer systems"	062 - Intrusion Detection System, slide 2	062 - Intrusion Detection System::s02::1	0.71	supported (ste gate)
2	A passive detection system can only log and alert when an attack is identified, and cannot actively stop an attack that is in progress.	"Can take passive action (logging and alerting) when an attack is identified"	062 - Intrusion Detection System, slide 29	062 - Intrusion Detection System::s29::1	0.46 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 062 - Intrusion Detection System, slide 2; 062 - Intrusion Detection System, slide 29

A8b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

State six (6) points about threat classes and the countermeasures used against them, covering how threats differ from vulnerabilities and attacks, how misuse-based detection recognises known attack patterns, and how preventive mechanisms such as firewalls, sandboxing and input sanitisation reduce the risk from malicious activity.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A threat is described as a potential violation of security, distinguishing it from an actual attack.	"Threats: A threat is a "potential" violation of security"	011 - Introduction to Computer Security, slide 9	011 - Introduction to Computer Security::s09::1	0.57	supported (ste gate)
2	An attack is the actual violation of security, as opposed to a mere vulnerability or threat.	"Attacks: The actual violation of security"	011 - Introduction to Computer Security, slide 9	011 - Introduction to Computer Security::s09::1	0.50	supported (ste gate)
3	Misuse detection represents attacks as patterns or signatures so that variations of the same attack can be recognised.	"there are ways to represent attacks in the form of a pattern or a signature so that even variations of the same attack can be detected"	062 - Intrusion Detection System, slide 17	062 - Intrusion Detection System::s17::1	0.80	supported (ste gate)
4	A firewall is a preventive countermeasure that controls incoming and outgoing network traffic according to predetermined security policies.	"Control incoming and outgoing traffic on network with predetermined security policies."	061 - Network Security, slide 3	061 - Network Security::s03::1	0.67	supported (ste gate)
5	Sandboxing counters threats by providing a safe, isolated environment in which suspected insecure programs or files can be run or opened.	"A safe, protected and isolated environment in computer system to run or open suspected insecure programs or files."	061 - Network Security, slide 26	061 - Network Security::s26::1	0.64	supported (ste gate)
6	The security of web applications depends crucially on sanitising user input to counter attacks such as XSS and XSRF.	"Security of web applications crucially depends on sanitisation of user input."	052 - Web Security, slide 22	052 - Web Security::s22::1	0.61	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 011 - Introduction to Computer Security, slide 9; 052 - Web Security, slide 22; 061 - Network Security, slide 26; 061 - Network Security, slide 3; 062 - Intrusion Detection System, slide 17

© Hak Cipta Universiti Teknologi MARA

PART A - QUESTION 9

A9a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain where network-based IDS sensors should be placed in a network and why their placement matters.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Sensors should be positioned at strategic points so that the most valuable assets are protected.	"Place IDS sensors strategically to defend most valuable assets"	062 - Intrusion Detection System, slide 7	062 - Intrusion Detection System::s07::1	0.56	supported (ste gate)
2	Typical sensor locations include just inside the firewall, on the DMZ, on the server farm segment, and on segments connecting mainframe or midrange hosts.	"Just inside the firewall"	062 - Intrusion Detection System, slide 7	062 - Intrusion Detection System::s07::1	0.20 LOW	partly supporte

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 062 - Intrusion Detection System, slide 7

A9b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain six preventive network security mechanisms and services that an organization can deploy to protect its network, describing what each mechanism does and how it contributes to securing network access and communication.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Remote Access VPN gives individual hosts or clients secure access to the organization's network from remote locations.	"Provides remote and secure access to an organization network to individual hosts or clients"	061 - Network Security, slide 4	061 - Network Security::s04::1	0.80	supported (ste gate)
2	Zero Trust Network Access restricts each user to only the access and permissions needed for their role.	"A user should only has access and permission that required to fulfill the role"	061 - Network Security, slide 4	061 - Network Security::s04::1	0.50	supported (ste gate)
3	Intrusion detection/prevention systems detect or prevent attacks such as brute force, denial-of-service, and exploitation of network vulnerabilities.	"To detect or prevent the network security attacks such as brute force attacks, Denial-of-Service attacks and exploits of network vulnerabilities."	061 - Network Security, slide 4	061 - Network Security::s04::1	0.85	supported (ste gate)
4	Preventive techniques such as firewalls, proxy servers, packet-filtering routers and network segmentation stop some intrusions, while IDS monitors for attacks that get past them.	"Monitors network resources to detect intrusions and attacks that were not stopped by preventative techniques (firewalls, proxy servers, packet-filtering routers, network segmentations)"	062 - Intrusion Detection System, slide 3	062 - Intrusion Detection System::s03::1	0.67	supported (ste gate)
5	Transport layer security (SSL/TLS) provides secure end-to-end communication over TCP that is not limited to HTTP.	"Secure end-to-end communication over TCP (not limited to HTTP)"	061 - Network Security, slide 18	061 - Network Security::s18::1	0.61	supported (ste gate)
6	Application layer	"Secure services (e.g.FTP, copy) over an insecure network"	061 - Network Security, slide	061 - Network Security::s22::1	0.46 LOW	partly supporte

© Hak Cipta Universiti Teknologi MARA

	security such as SSH secures remote login and services over an insecure network.		22			

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 061 - Network Security, slide 18; 061 - Network Security, slide 22; 061 - Network Security, slide 4; 062 - Intrusion Detection System, slide 3

PART A - QUESTION 10

A10a - 2 marks - supported by lecture slides (not lecturer-marked)

Question:

List the TWO (2) stages of the biometric authentication process.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Identification stage, in which master characteristics are acquired, created and stored	"Identification Stage Acquisition Creation of Master characteristics Storage of Master characteristics"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s05::1	0.50	supported (ste gate)
2	Authentication stage, in which acquisition is repeated and followed by comparison and a decision	"Authentication Stage Acquisition(s) Comparison Decision"	072 - Biometrics and Authentication, slide 5	072 - Biometrics and Authentication::s05::1	0.71	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 072 - Biometrics and Authentication, slide 5

A10b - 6 marks - supported by lecture slides (not lecturer-marked)

Question:

Compare the two categories of biometric applications available today by identifying the biometric technologies that belong to each category, and then discuss three disadvantages associated with fingerprint biometrics.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Biometric applications are divided into two sectors, namely psychological and behavioural.	"Biometric applications available today are categorized into 2 sectors"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.57	supported (ste gate)
2	The psychological category includes iris, fingerprints, hand, retinal and face recognition.	"Psychological: Iris, Fingerprints, Hand, Retinal and Face recognition"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.78	supported (ste gate)
3	The behavioural category includes voice, typing pattern and signature.	"Behavioural: Voice, Typing pattern, Signature"	072 - Biometrics and Authentication, slide 4	072 - Biometrics and Authentication::s04::1	0.67	supported (ste gate)
4	Fingerprint biometrics suffer from racial issues.	"Racial issues"	072 - Biometrics and Authentication, slide 7	072 - Biometrics and Authentication::s07::1	0.40 LOW	partly supporte
5	Fingerprint readings are affected by dirt, grime and wounds.	"Dirt , grime and wounds"	072 - Biometrics and Authentication, slide 7	072 - Biometrics and Authentication::s07::1	0.50	supported (ste gate)
6	Fingerprint biometrics can be spoofed, so liveness detection is important.	"Can be spoofed - liveness important!"	072 - Biometrics and Authentication, slide 7	072 - Biometrics and Authentication::s07::1	0.57	supported (ste gate)

© Hak Cipta Universiti Teknologi MARA

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 072 - Biometrics and Authentication, slide 4; 072 - Biometrics and Authentication, slide 7

PART B - QUESTION 1

B1a - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

State the role of a reference monitor in authorization and outline the four goals of access control. Then state the specific concern that the Chinese Wall policy is designed to address and explain why its permissions change dynamically.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	A reference monitor is the component that makes authorization decisions.	"Reference monitor makes authorization decisions."	023 - Access Control and Authorization, slide 4	023 - Access Control and Authorization::s04::1	1.00	supported (ste gate)
2	One goal of access control is granting access.	"Goals of access control: Granting access"	023 - Access Control and Authorization, slide 4	023 - Access Control and Authorization::s04::1	1.00	supported (ste gate)
3	Another goal is limiting access.	"Limiting access"	023 - Access Control and Authorization, slide 4	023 - Access Control and Authorization::s04::1	0.50	supported (ste gate)
4	The Chinese Wall policy is designed to address conflicts of interest by a consultant or contractor.	"Brewer and Nash's Chinese Wall Policy is designed to address a very specific concern: conflicts of interest by a consultant or contractor."	024 - Formal Security Model, slide 27	024 - Formal Security Model::s27::1	1.00	supported (ste gate)
5	Permissions change dynamically because access rights depend on the history of past accesses.	"The access rights that any subject enjoys depends on the history of past accesses"	024 - Formal Security Model, slide 24	024 - Formal Security Model::s24::1	0.56	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 023 - Access Control and Authorization, slide 4; 024 - Formal Security Model, slide 24; 024 - Formal Security Model, slide 27

B1b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the Chinese Wall model by stating the conflict it is designed to resolve, its classification as a policy type, the condition under which a subject may be granted access to an object, and the two conditions that must hold before write access is permitted.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	The Chinese Wall policy was proposed by Brewer and Nash to address conflicts of interest.	"Brewer and Nash (1989) proposed a policy called the Chinese Wall Policy that addresses such conflicts of interest."	024 - Formal Security Model, slide 21	024 - Formal Security Model::s21::1	1.00	supported (ste gate)
2	It is classified as an access control confidentiality policy rather than an integrity policy.	"Strictly speaking, this is not an integrity policy, but an access control confidentiality policy."	024 - Formal Security Model, slide 21	024 - Formal Security Model::s21::1	0.62	supported (ste gate)
3	Under the simple security rule, a subject may access an object only if that object lies within the same	"is in the same company datasets as the objects already accessed by s,"	024 - Formal Security Model, slide 25	024 - Formal Security Model::s25::1	0.38 LOW	supported

© Hak Cipta Universiti Teknologi MARA

	company datasets already accessed (within the Wall).					
4	Alternatively, access is allowed if the object belongs to a completely different conflict of interest class.	"belongs to an entirely different conflict of interest class."	024 - Formal Security Model, slide 25	024 - Formal Security Model::s25::1	0.44 LOW	supported
5	Write access is allowed only when the simple security rule permits it and no readable object in a different company dataset holds unsanitized information.	"Write access is only permitted if: access is permitted by the simple security rule, and no object can be read which is: in a different company dataset than the one for which write access is requested, and contains unsanitized information."	024 - Formal Security Model, slide 26	024 - Formal Security Model::s26::1	0.75	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Citations: 024 - Formal Security Model, slide 21; 024 - Formal Security Model, slide 25; 024 - Formal Security Model, slide 26

PART B - QUESTION 2

B2a - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Discuss FIVE (5) password security controls that an administrator can apply to protect user accounts on a Linux system, and explain how each control reduces the risk of unauthorized access.

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Apply access control to the password files so that ordinary users cannot read stored password data.	"Access control applied to password files"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.36 LOW	partly supporte
2	De-activate an account after several failed login attempts to block repeated guessing.	"De-activation of accounts after multiple failed logins"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.50	supported (ste gate)
3	Show the time of the last login so a user can notice suspicious account use.	"Displaying the time of a last login"	022 - Identification and Authentication, slide 12	022 - Identification and Authentication::s12::1	0.33 LOW	partly supporte
4	Store passwords only in encrypted form using a one-way hash function rather than plaintext.	"Password is stored in an encrypted form using a one-way hash function:"	022 - Identification and Authentication, slide 8	022 - Identification and Authentication::s08::1	0.64	supported (ste gate)
5	Enforce password expiration so that a compromised password causes damage only for a limited period.	"Password expiration reduces the damage but increases the risk of forgetting."	022 - Identification and Authentication, slide 10	022 - Identification and Authentication::s10::1	0.33 LOW	supported

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 022 - Identification and Authentication, slide 10; 022 - Identification and Authentication, slide 12; 022 - Identification and Authentication, slide 8

B2b - 5 marks - supported by lecture slides (not lecturer-marked)

Question:

Explain the design criteria that Kerberos aims to satisfy and the benefits that single sign-on solutions such as Kerberos bring to large distributed environments.

© Hak Cipta Universiti Teknologi MARA

Marking points:

No.	Point (1 mark)	Evidence quote	Source	Chunk	Stem overlap	Entailment
1	Kerberos is designed to be secure against eavesdropping by never transmitting passwords in clear text.	"Security against eavesdropping: no password transmission in clear text."	022 - Identification and Authentication, slide 18	022 - Identification and Authentication::s18::1	0.60	supported (ste gate)
2	Kerberos is designed for reliability, since every use of a service requires prior authentication.	"Reliability: every use of a service requires prior authentication."	022 - Identification and Authentication, slide 18	022 - Identification and Authentication::s18::1	0.67	supported (ste gate)
3	Kerberos is designed for transparency, so the user is unaware of any authentication beyond the initial login.	"Transparency: user is not aware of any authentication beyond an initial login."	022 - Identification and Authentication, slide 18	022 - Identification and Authentication::s18::1	0.70	supported (ste gate)
4	Kerberos is designed for scalability, supporting a large number of servers and clients.	"Scalability: support for a large number of servers and clients."	022 - Identification and Authentication, slide 18	022 - Identification and Authentication::s18::1	0.75	supported (ste gate)
5	Single sign-on methods such as Kerberos automate authentication in large distributed environments.	"Single sign-on methods such as Kerberos provide means for automating authentication in large distributed environments."	022 - Identification and Authentication, slide 24	022 - Identification and Authentication::s24::1	1.00	supported (ste gate)

Confidence: supported by lecture slides (not lecturer-marked) - each point carries a verbatim quote from the cited lecture slide.
Style confidence: LOW - exact examples n<3; widened via topic+marks (any command).
Citations: 022 - Identification and Authentication, slide 18; 022 - Identification and Authentication, slide 24

End of marking scheme.

© Hak Cipta Universiti Teknologi MARA